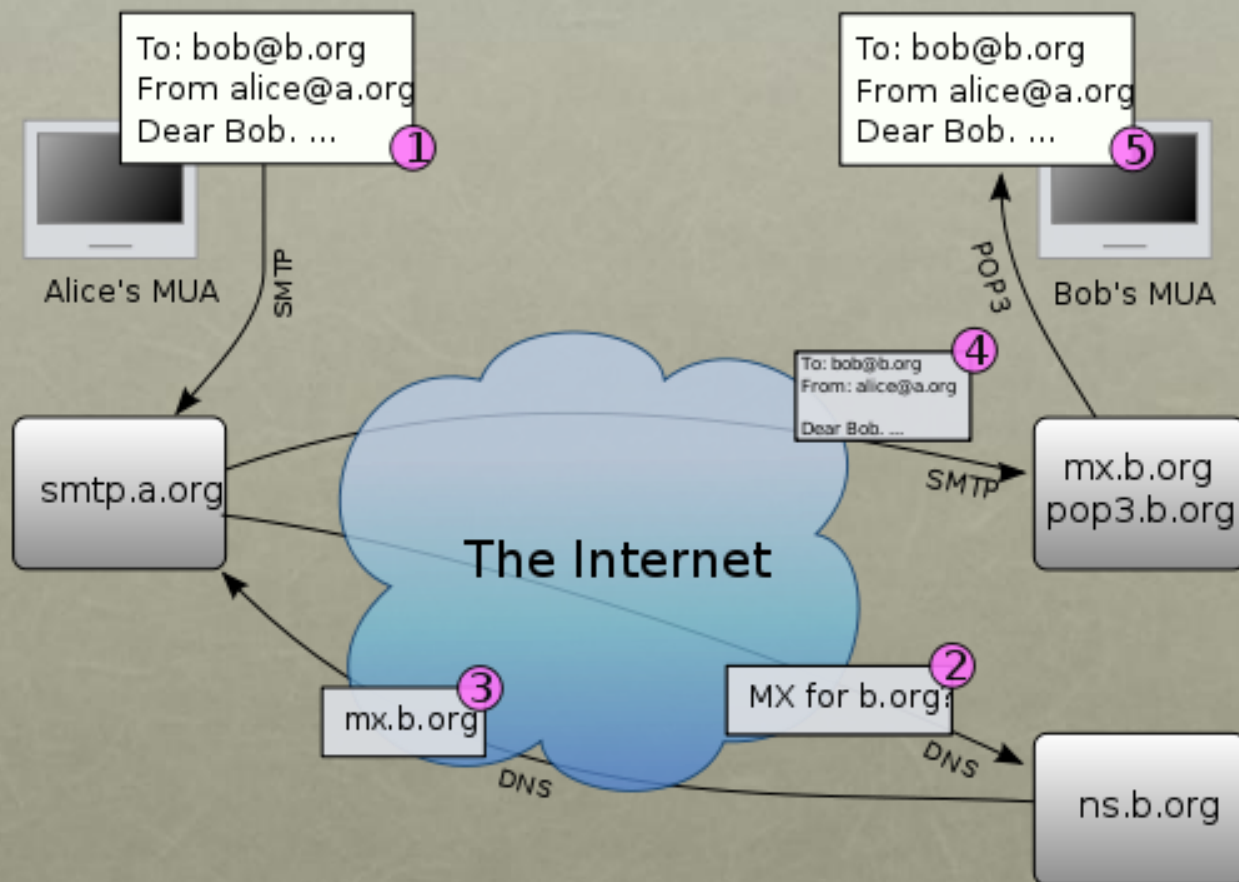
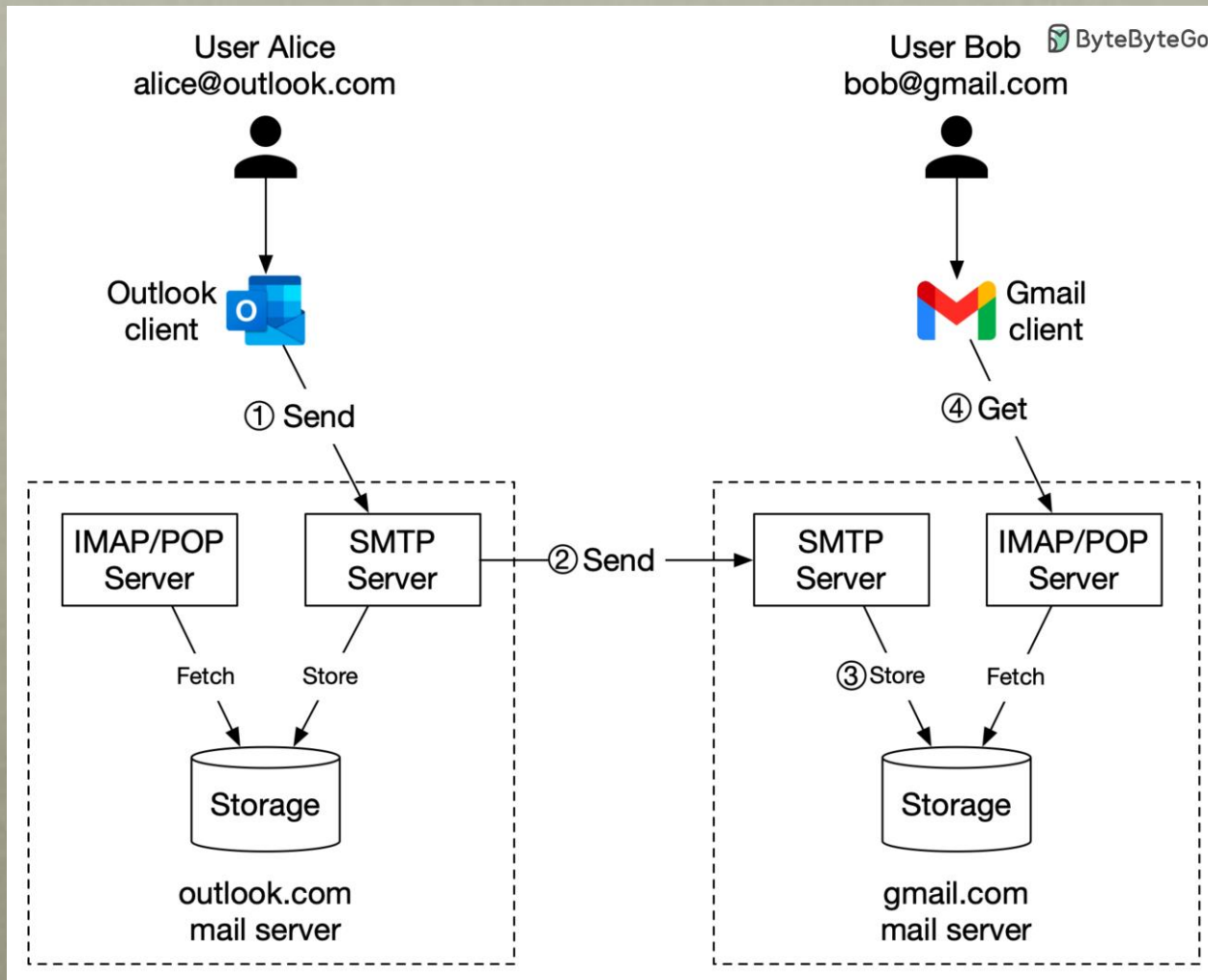


Electronic Mail Security

MAIL



MAIL



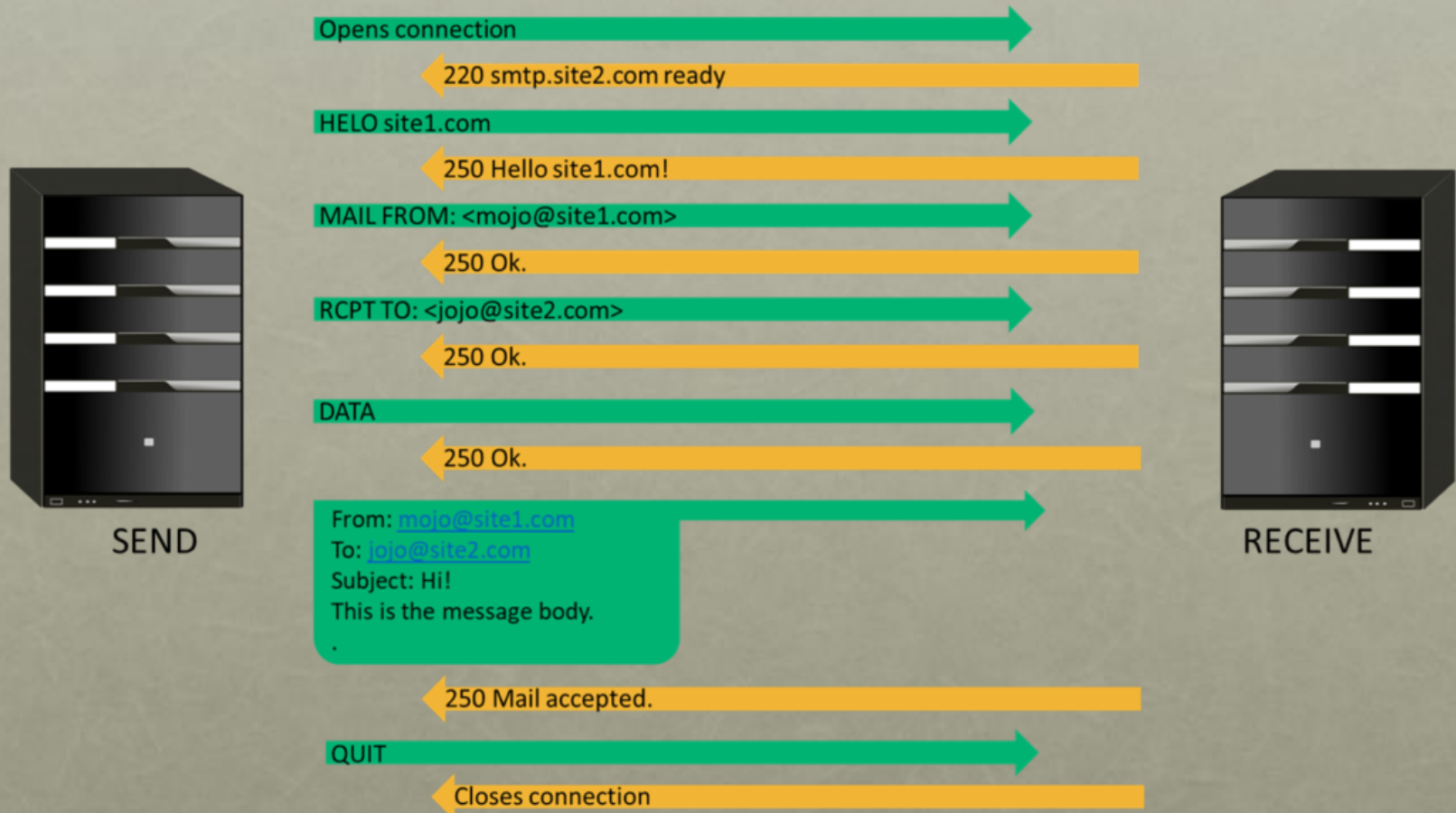
E-MAIL SECURITY

- E-mail is one of the most widely used network services
 - One of the old killer applications of the Internet
- Normally message contents not secured
 - Can be read/modified either in transit or at destination by the attacker
- E-mail service is like postcard service
 - just pick it and read it

EMAIL SECURITY ENHANCEMENTS

- **confidentiality**
 - protection from disclosure
- **authentication**
 - of sender of message
- **message integrity**
 - protection from modification
- **non-repudiation of origin**
 - protection from denial by sender

SMTP - THREATS

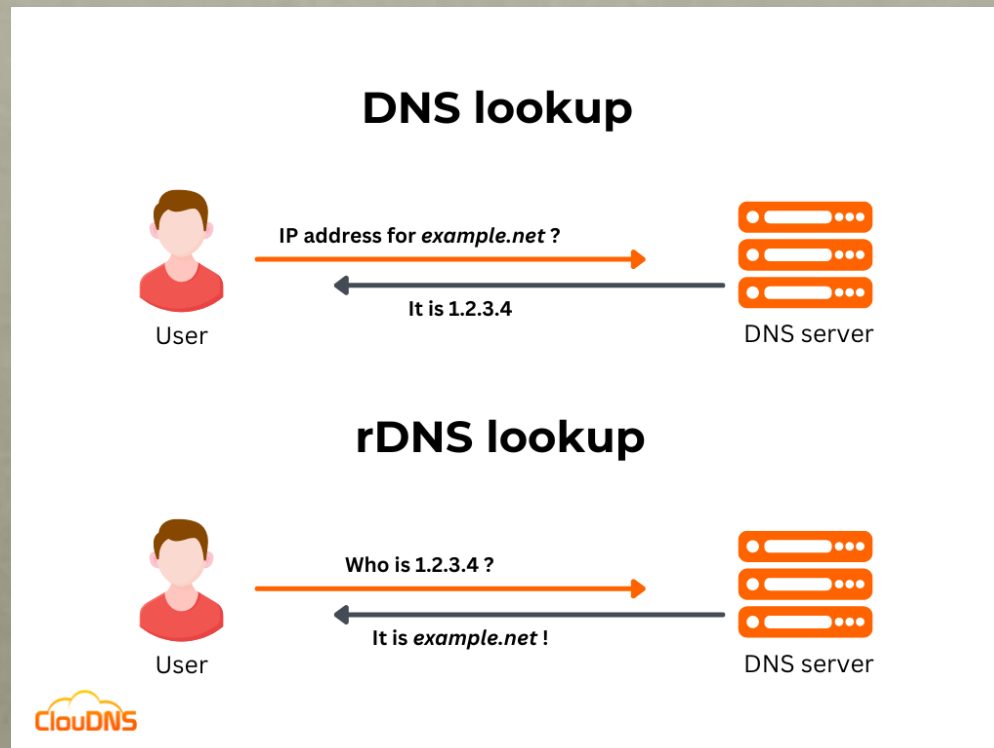


E-MAIL THREATS

- Data security
 - Network
 - Mail server
- SPAM
 - Bandwidth
 - System resources
- Phishing
- Malware
- Ransomware

REVERSE DNS

- SPAM reduction
- Server side



SENDER POLICY FRAMEWORK (SPF)

- Current email infrastructure allows to use any domain name while sending during SMTP messaging and in the email header.

```
S: 220 foo.com Simple Mail Transfer Service Ready
C: HELO mta.example.net
S: 250 OK
C: MAIL FROM:<alice@example.org>
S: 250 OK
C: RCPT TO:<Jones@foo.com>
S: 250 OK
C: DATA
S: 354 Start mail input; end with <CRLE>.<CRLE>
C: To: bob@foo.com
C: From: alice.sender@example.net
C: Date: Today
C: Subject: Meeting Today
. . .
```

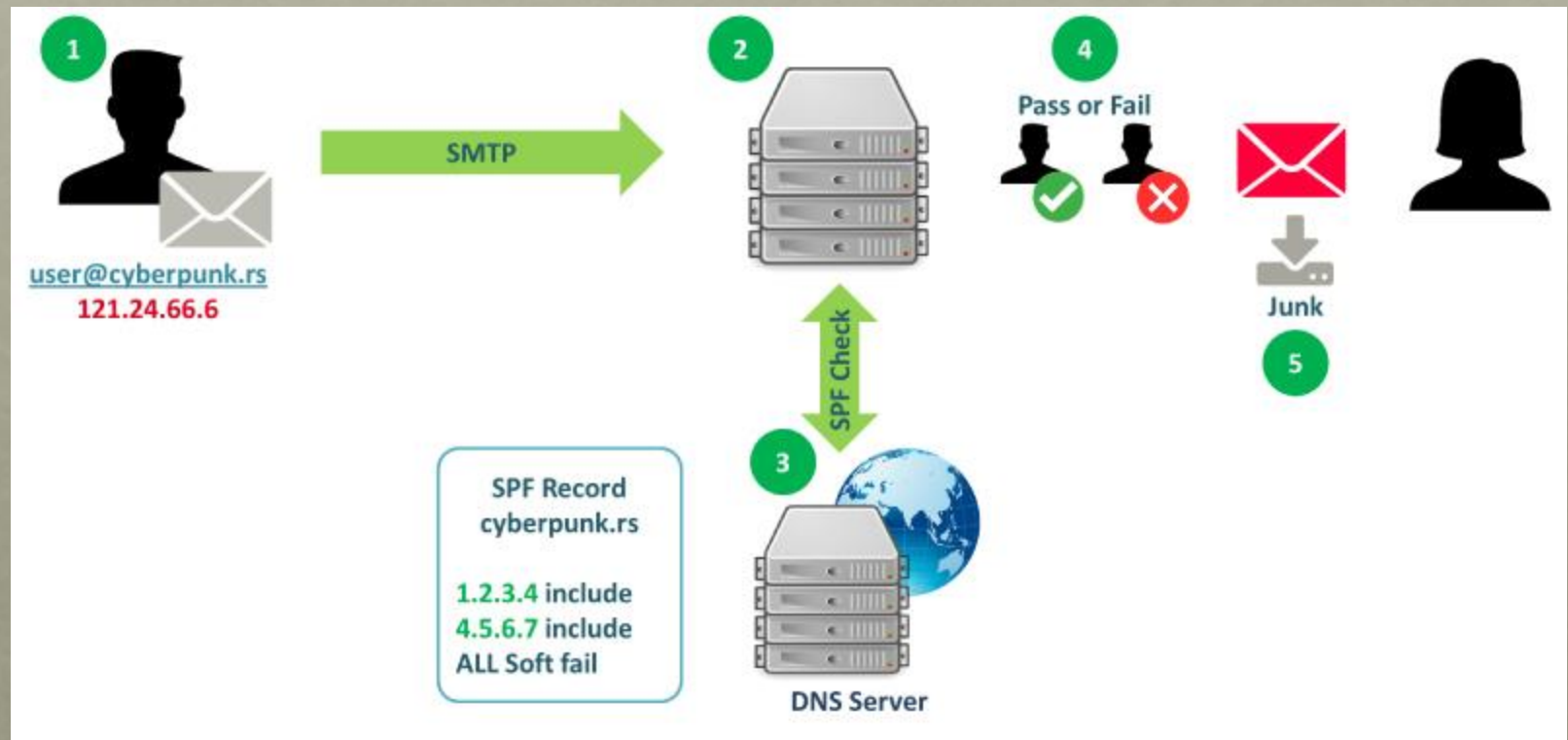
No domain
name
check is
done

SENDER POLICY FRAMEWORK (SPF)

- SPF is the standardized way for a sending domain to identify and assert the mail senders for that domain
- SPF works by checking a sender's IP address against the policy encoded in any SPF record found at the sending domain DNS records
 - This means that SPF checks can be applied before the message content is received from the sender (from: field in the message header is not checked)
- SPF policies are stored in TXT type DNS resource records (SPF TXT RR)

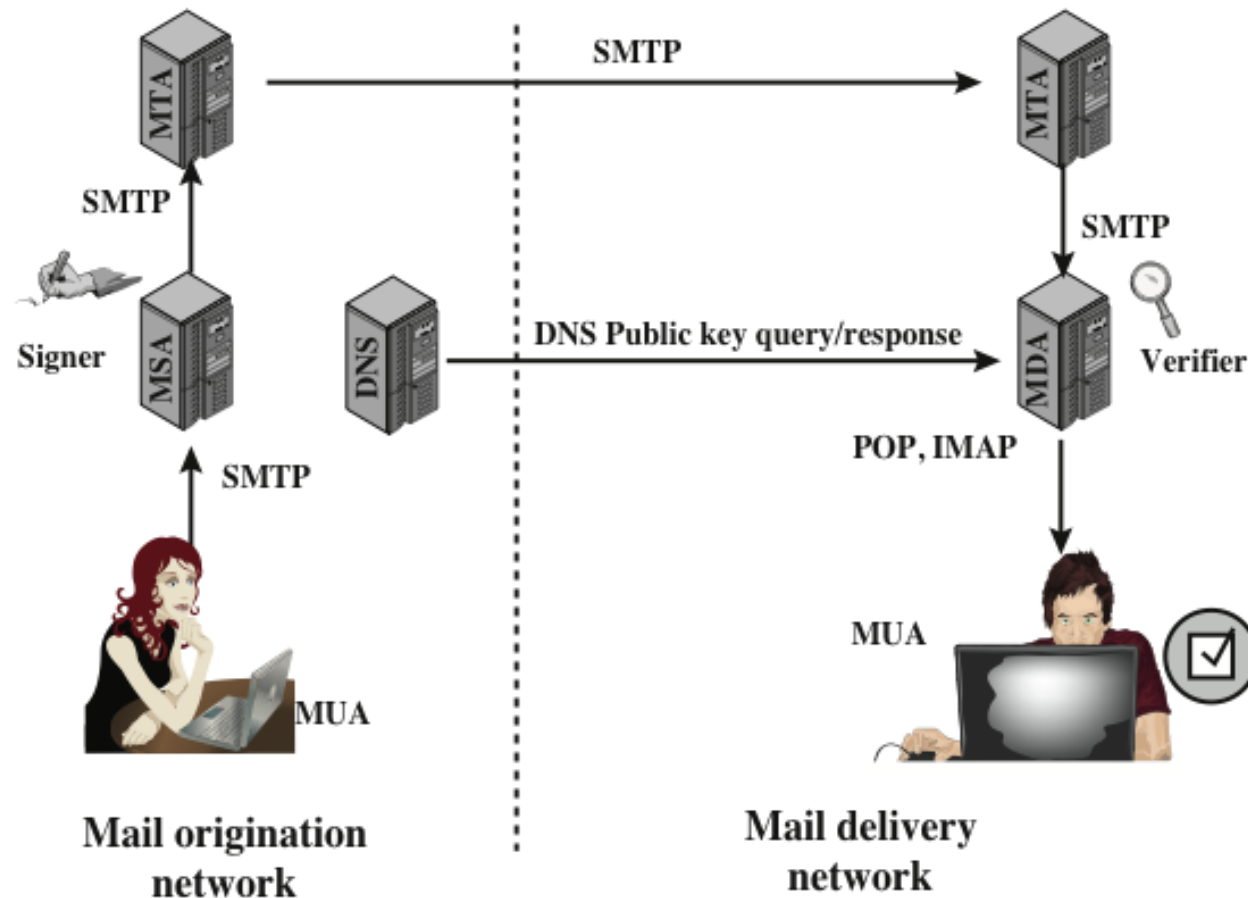
SPF

- SPAM
- Server



DOMAINKEYS IDENTIFIED MAIL (DKIM)

- A specification for cryptographically signing e-mail messages, permitting a signing domain to claim responsibility for a message in the mail stream
- Message recipients can verify the signature by querying the signer's domain directly to retrieve the appropriate public key and can thereby confirm that the message was attested to by a party in possession of the private key for the signing domain
- Proposed Internet Standard RFC 4871
- Has been widely adopted by a range of e-mail providers and Internet Service Providers (ISPs)



DNS = domain name system
MDA = mail delivery agent
MSA = mail submission agent
MTA = message transfer agent
MUA = message user agent

Figure 8.5 Simple Example of DKIM Deployment

Received: from o1.email.jvzoo.com (o1.email.jvzoo.com. [50.31.35.16])
by mx.google.com with ESMTPS id dlsi4393468igl.23.2015.11.25.00.54.19
for [REDACTED]
(version=TLS1_2 cipher=ECDHE-RSA-AES128-GCM-SHA256 bits=128/128);
Wed, 25 Nov 2015 00:54:19 -0800 (PST)
Received-SPF: pass (google.com: domain of bounces+99685-7b19-[REDACTED]@email.jvzoo.com designates 50.31.35.16 as
permitted sender) client-ip=50.31.35.16;
Authentication-Results: mx.google.com;
spf=pass google.com: domain of bounces+99685-7b19-[REDACTED]@email.jvzoo.com designates 50.31.35.16 as
permitted sender) smtp.mailfrom=bounces+99685-7b19-[REDACTED]@email.jvzoo.com;
dkim=pass header.i=@sendgrid.info
X-IM-Signature v=1; a=rsa-sha1; c=relaxed; d=sendgrid.info;
h=to:subject:from:x-feedback-id; s=smtpapi;
bh=oEi5G7FpHY8LWy9H6B65ArvEJ98=; b=wA6npEYqtPsjpSIKBQthPP5waBLD/
Lv7DucfMKx3IiML9KqTwIyhgM9aZHHd6Cd9caL4EE9yDkdstigzN7GAI1rCZXln
XjHRcHXNLHwcEu4sqTtWoV5aDkvGmIaB10tNFmeyd2hnFAPoo2SYSwUfm/xG9t72
NDiJIK1VKE2GS4=

PRETTY GOOD PRIVACY (PGP)

- Provides a **confidentiality** and **authentication** service that can be used for electronic mail and file storage applications
- Developed by Phil Zimmermann
 - Selected the best available cryptographic algorithms as building blocks
 - Integrated these algorithms into a general-purpose application that is independent of operating system and processor and that is based on a small set of easy-to-use commands
 - Made the package and its documentation, including the source code, freely available via the Internet, bulletin boards, and commercial networks
 - Entered into an agreement with a company to provide a fully compatible, low-cost commercial version of PGP

PGP MECHANISMS

- Digital Signatures (and consequently message authentication and integrity)
 - RSA, DSS, and others
- Message Encryption
 - CAST, IDEA, 3DES, AES, etc. (all at least 128 bits)
 - symmetric keys are used once and encrypted using RSA or ElGamal (based on discrete logs)
- Compression using ZIP
- Radix-64 conversion (to ASCII)
 - for e-mail compatibility

PGP AUTHENTICATION

- Combination of SHA-1 and RSA provides an effective digital signature scheme
 - Because of the strength of RSA the recipient is assured that only the possessor of the matching private key can generate the signature
 - Because of the strength of SHA-1 the recipient is assured that no one else could generate a new message that matches the hash code
 - As an alternative, signatures can be generated using DSS/SHA-1
 - Detached signatures are supported
 - Each person's signature is independent and therefore applied only to the document



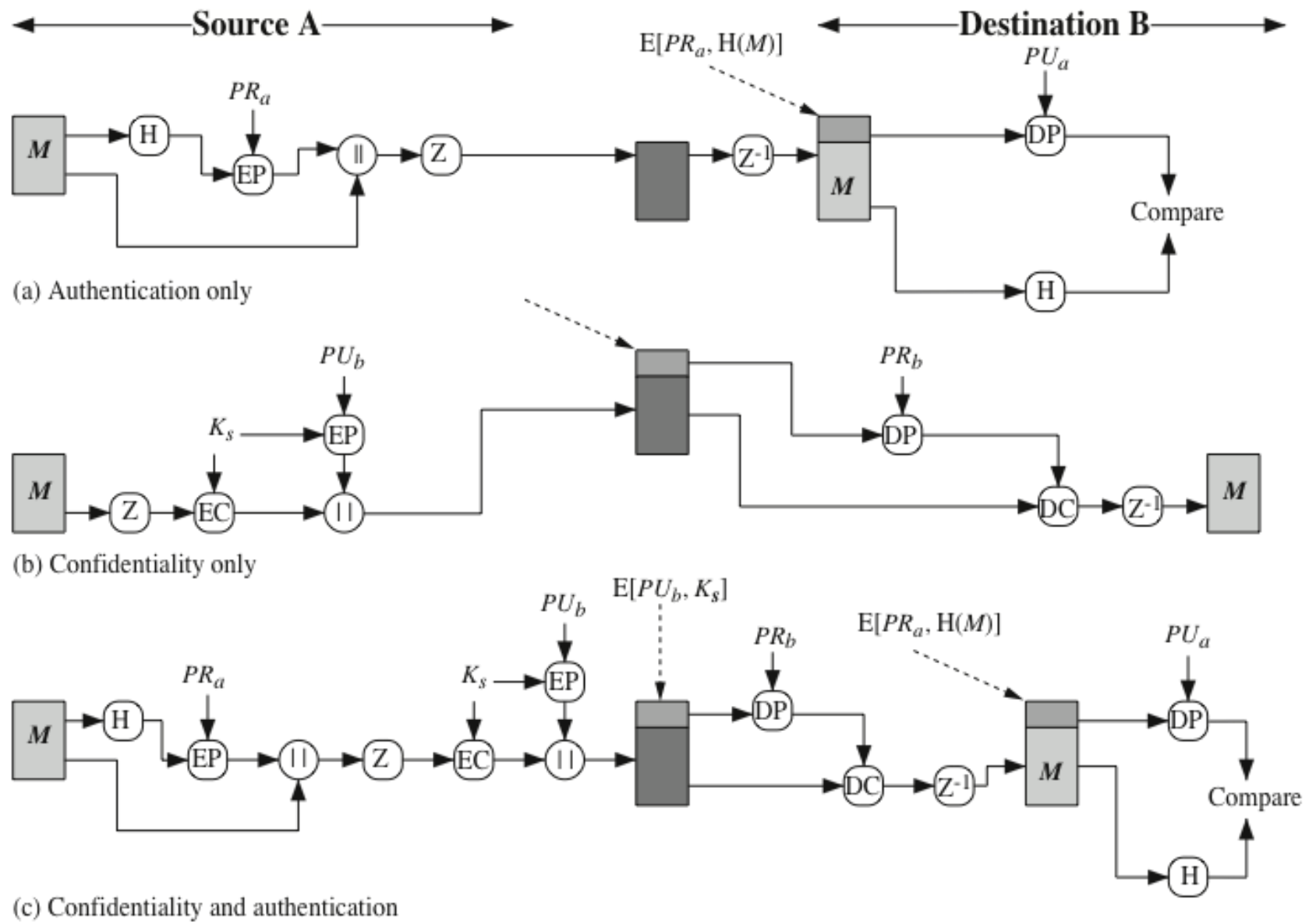


Figure 8.1 PGP Cryptographic Functions

PGP CONFIDENTIALITY

- Provided by encrypting messages to be transmitted or to be stored locally as files
 - In both cases the symmetric encryption algorithm CAST-128 may be used
 - Alternatively IDEA or 3DES may be used
 - The 64-bit cipher feedback (CFB) mode is used

In PGP each symmetric key is used only once

- Although referred to as a session key, it is in reality a one-time key
 - Session key is bound to the message and transmitted with it
 - To protect the key, it is encrypted with the receiver's public key
- As an alternative to the use of RSA for key encryption, PGP uses ElGamal, a variant of Diffie-Hellman that provides encryption/decryption

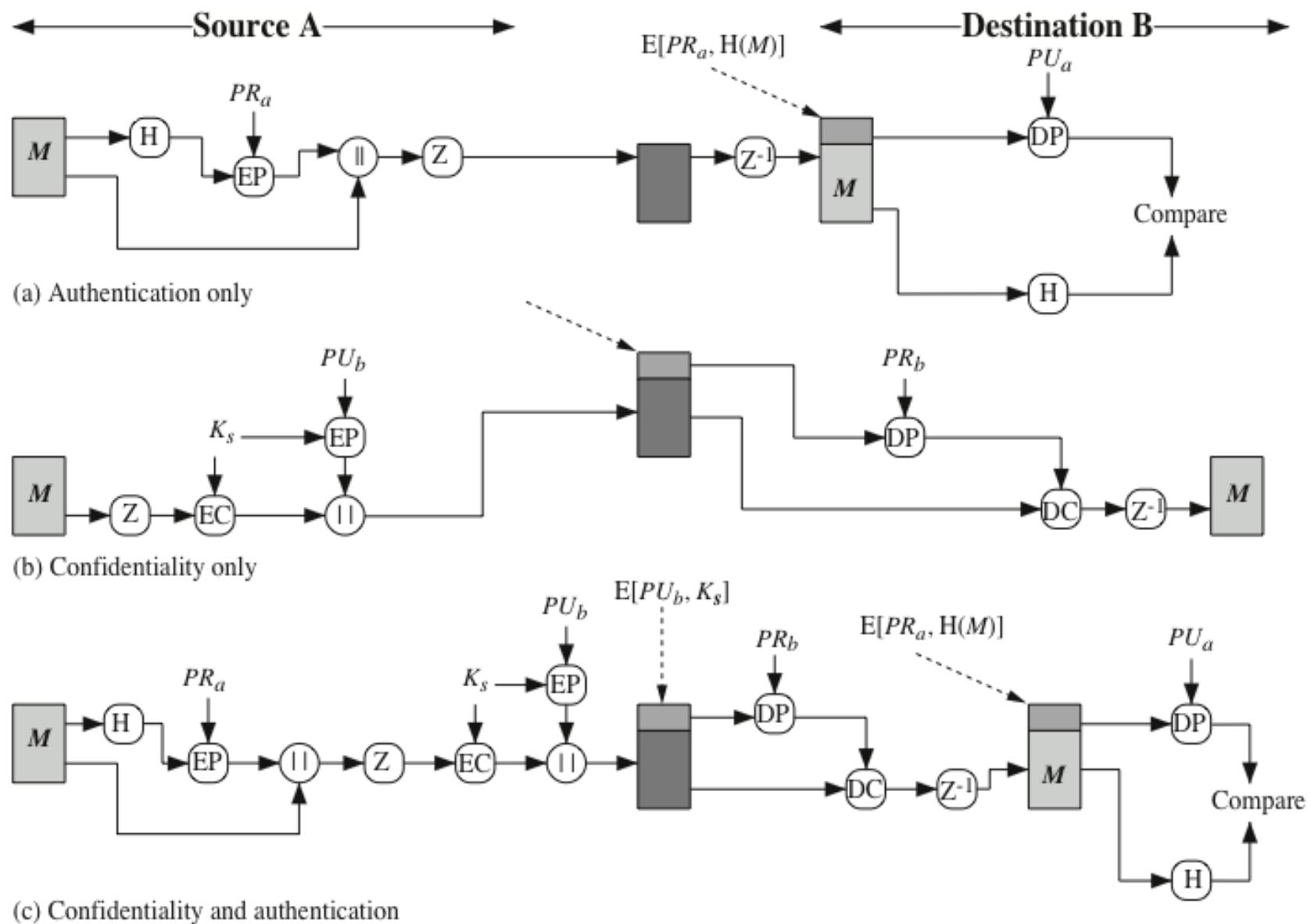


Figure 8.1 PGP Cryptographic Functions

PGP CONFIDENTIALITY AND AUTHENTICATION

- Both services may be used for the same message
 - First a signature is generated for the plaintext message and prepended to the message
 - Then the plaintext message plus signature is encrypted using CAST-128 (or IDEA or 3DES) and the session key is encrypted using RSA (or ElGamal)
- When both services are used:



The sender first
signs the message
with its own private
key

Then encrypts the
message with a
session key

And finally
encrypts the
session key with
the recipient's
public key

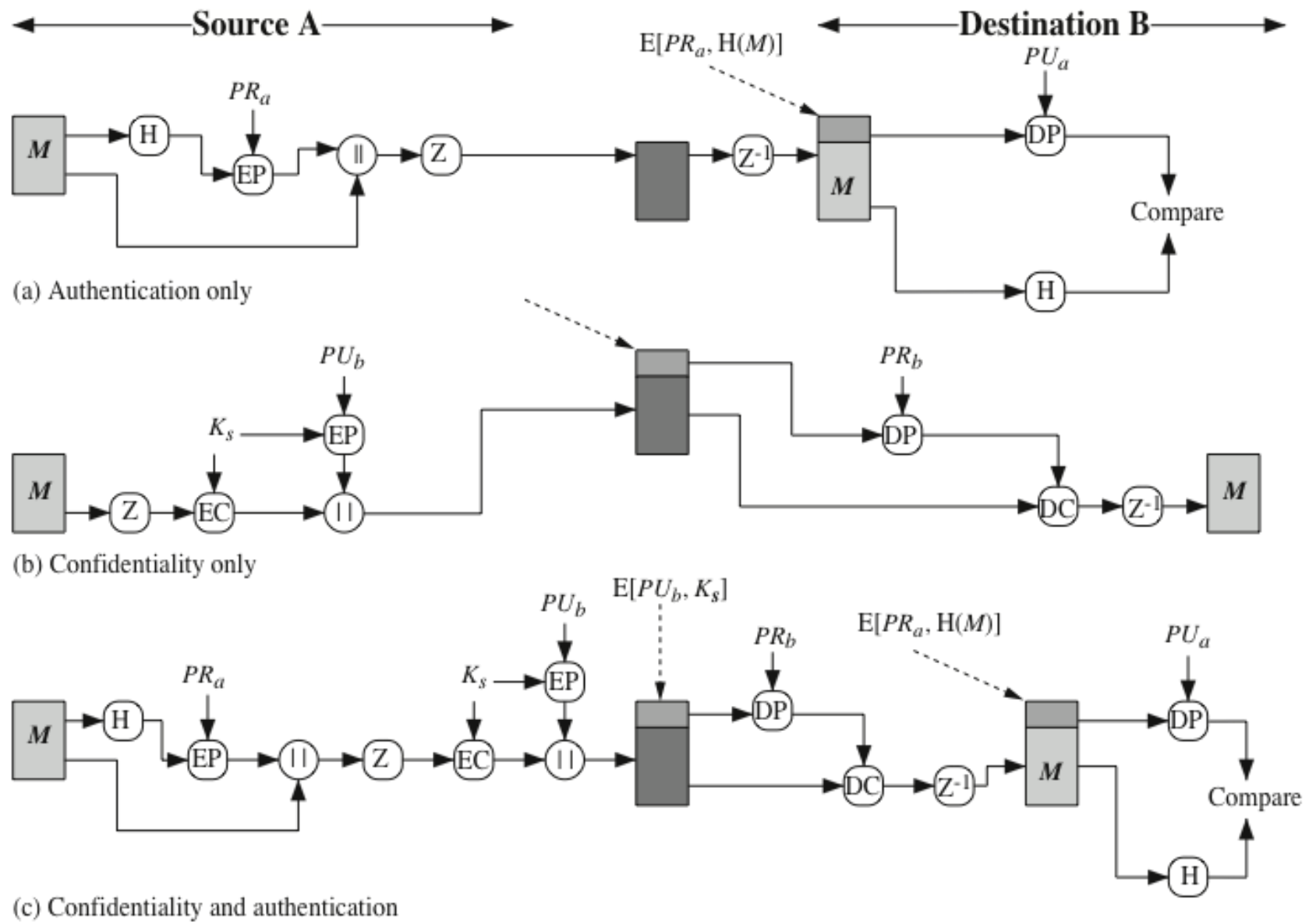


Figure 8.1 PGP Cryptographic Functions

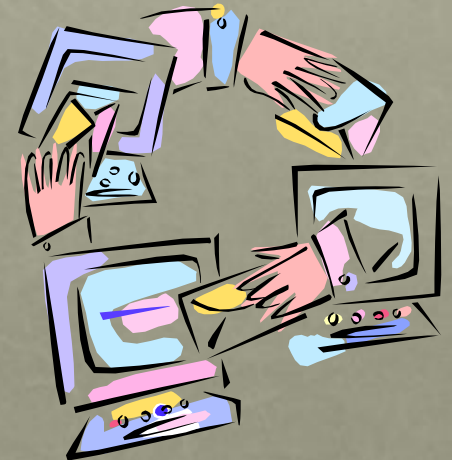
PGP COMPRESSION

- As a default, PGP compresses the message after applying the signature but before encryption
 - This has the benefit of saving space both for e-mail transmission and for file storage
 - The placement of the compression algorithm is critical
 - Applying the hash function and signature after compression would constrain all PGP implementations to the same version of the compression algorithm
 - Message encryption is applied after compression to strengthen cryptographic security
 - The compression algorithm used is ZIP



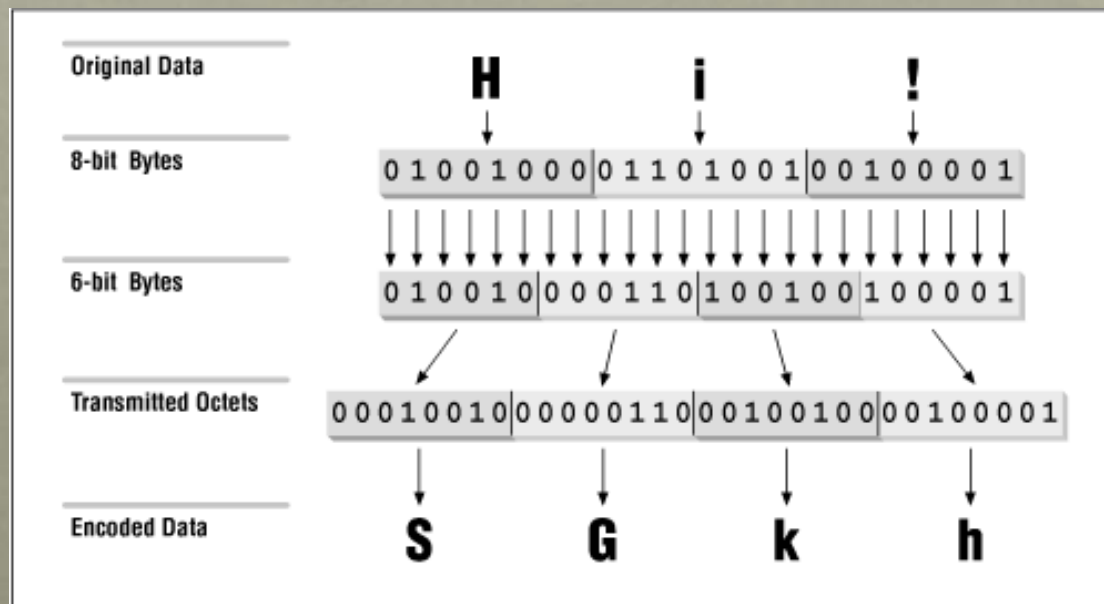
PGP E-MAIL COMPATIBILITY

- Many electronic mail systems only permit the use of blocks consisting of ASCII text
 - To accommodate this restriction, PGP provides the service of converting the raw 8-bit binary stream to a stream of printable ASCII characters
 - The scheme used for this purpose is radix-64 conversion
 - Each group of three octets of binary data is mapped into four ASCII characters
 - This format also appends a CRC to detect transmission errors



RADIX-64

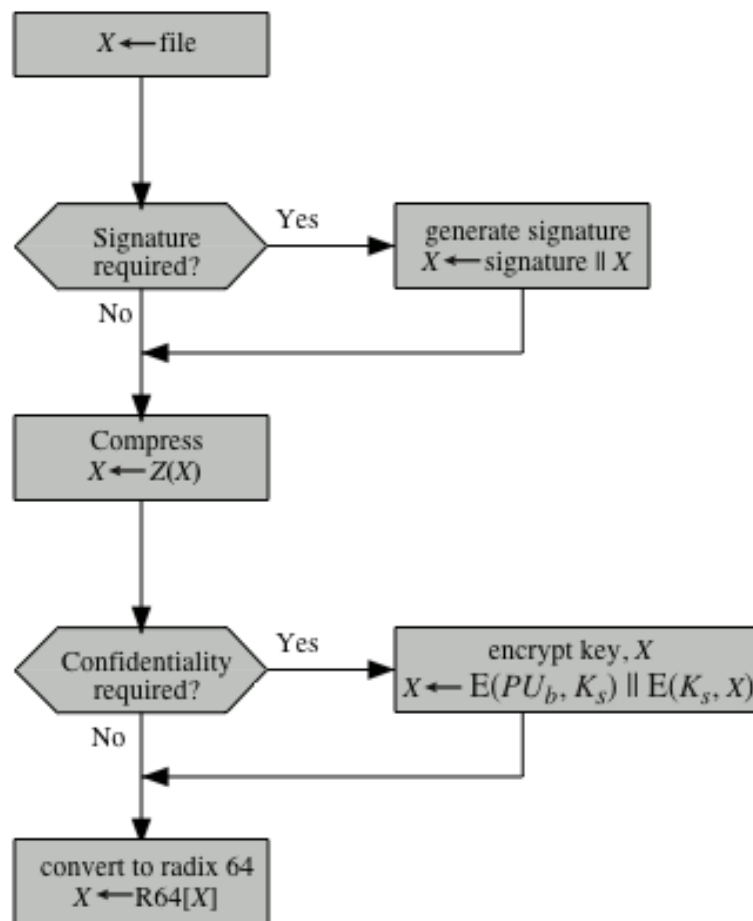
- The binary input is split into blocks of 24 bits (3 bytes).
- Each 24 block is then split into four sets each of 6-bits.
- Each 6-bit set will then have a value between 0 and 26-1 (=63).
- This value is encoded into a printable character.



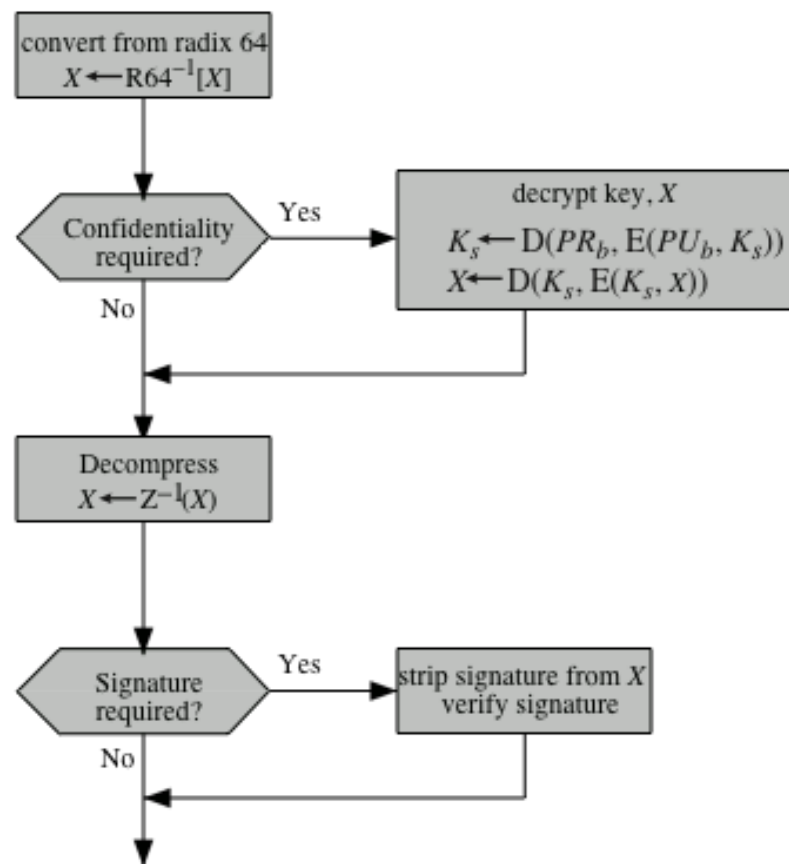
RADIX-64

The Base64 index table:

Index	Binary	Char	Index	Binary	Char	Index	Binary	Char	Index	Binary	Char
0	000000	A	16	010000	Q	32	100000	g	48	110000	w
1	000001	B	17	010001	R	33	100001	h	49	110001	x
2	000010	C	18	010010	S	34	100010	i	50	110010	y
3	000011	D	19	010011	T	35	100011	j	51	110011	z
4	000100	E	20	010100	U	36	100100	k	52	110100	θ
5	000101	F	21	010101	V	37	100101	l	53	110101	1
6	000110	G	22	010110	W	38	100110	m	54	110110	2
7	000111	H	23	010111	X	39	100111	n	55	110111	3
8	001000	I	24	011000	Y	40	101000	o	56	111000	4
9	001001	J	25	011001	Z	41	101001	p	57	111001	5
10	001010	K	26	011010	a	42	101010	q	58	111010	6
11	001011	L	27	011011	b	43	101011	r	59	111011	7
12	001100	M	28	011100	c	44	101100	s	60	111100	8
13	001101	N	29	011101	d	45	101101	t	61	111101	9
14	001110	O	30	011110	e	46	101110	u	62	111110	+
15	001111	P	31	011111	f	47	101111	v	63	111111	/
Padding		=									



(a) Generic Transmission Diagram (from A)



(b) Generic Reception Diagram (to B)

Figure 8.2 Transmission and Reception of PGP Messages

PGP KEY ID CONCEPT

- since a user may have many **public/private keys** in use, there is a need to identify which is actually used to encrypt the session key in a message
 - PGP uses a key identifier which is least significant 64-bits of the public key
- Key IDs are used in signatures too
 - key ID for the public key corresponding to the private key used for signature
- Key IDs are sent together with messages

PGP KEY RINGS

- each PGP user has a pair of keyrings to store public and private keys
 - **public-key** ring contains all the public-keys of other PGP users known to this user
- **private-key** ring contains the public/private key pair(s) for this user,
- **private keys** are encrypted using a key derived from a hashed passphrase

PGP KEY MANAGEMENT

- You have to make sure about the legitimacy of the public key of your party
 - exchange public-keys manually (using CDs, USB sticks, etc.)
 - verify fingerprint of a public key over the phone
 - trust another individual who signs public keys
 - public key signatures
- **in PGP each user is a CA**
 - everybody can sign keys of users they know directly
 - other users' key signatures can also be used, if those users are trusted

MIME

- MIME (Multipurpose Internet Mail Extensions) is an extension of the original Simple Mail Transport Protocol (SMTP) email protocol. It lets users exchange different kinds of data files, including audio, video, images and application programs, over email.
 - content type
 - Almost any type of information can appear in an email message
 - transfer encoding
 - specifies how the message body is encoded into textual form (radix64 is common)

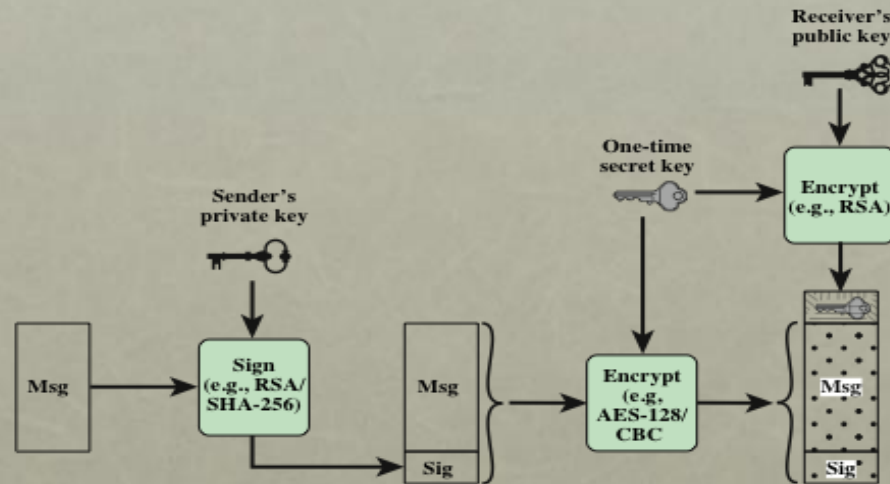
S/MIME

- Secure/Multipurpose Internet Mail Extensions
- A standard way for email **encryption** and **signing**
- Industry support
- Not a standalone software, a system that is to be supported by email clients
 - such as MS Outlook and Thunderbird
- S/MIME handles digital signatures
 - Also provides encryption

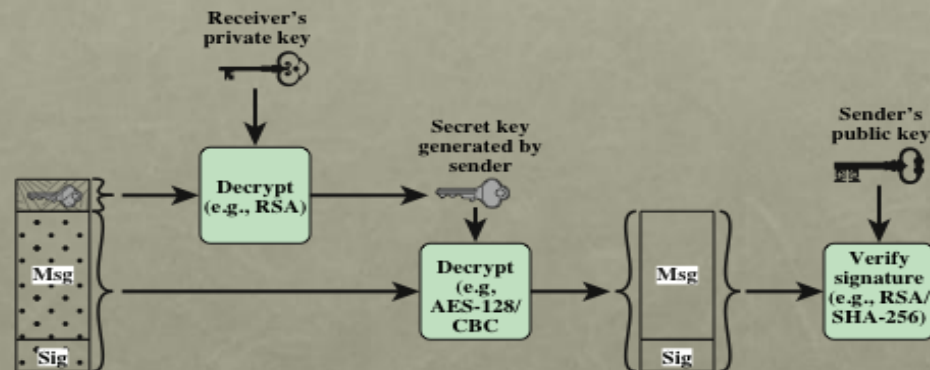
S/MIME CRYPTOGRAPHIC ALGORITHMS

- hash functions: switched to SHA256
- digital signatures: Mostly RSA is used
- session key encryption: Mostly RSA is used
- message encryption: Triple-DES, AES and others, but AES-128 is preferred
- Base64 (radix64) encoding is used for email compatibility (ASCII conversion)
- sender should know the capabilities of the receiving entity (public announcement or previously received messages from receiver)

S/MIME SECURITY FUNCTIONALITY:



(a) Sender signs, then encrypts message



(b) Receiver decrypts message, then verifies sender's signature

S/MIME CERTIFICATE PROCESSING

- S/MIME uses X.509 v3 certificates
 - Certification Authorities (CAs) issue certificates
 - unlike PGP, a user cannot be a CA
- each client has a list of trusted CA certificates
 - actually that list comes with e-mail client software or OS
- and own public/private key pairs and certs

SUMMARY

- Pretty good privacy
 - Notation
 - Operational description
- DomainKeys Identified Mail
 - Internet mail architecture
 - E-mail threats
 - DKIM strategy
 - DKIM functional flow